דוח בדיקת נאותות סיכונים מוסדיים V1.1 • תקן הגנה קריפטוגרפי

HAICHAIN: דוח בדיקת נאותות סיכונים מוסדיים

הוכחות מתמטיות, מידול איומים ומטריצת אימות רד-טים עבור קרנות Tier-1 וחברות ביקורת

קהל יעד
קרנות מובילות וחברות ביקורת

אבטחה קריפטוגרפית
מפתח חומרה 9 • Passkey אינווריאנטים

ליבת הפרוטוקול
HAICHAIN v1.1 • CapLeaf 223 בייטים

דוח בדיקת נאותות סיכונים מוסדיים ואבטחת קריפטוגרפיה של HAICHAIN

הוכחות מתמטיות, מידול איומים ומטריצת אימות רד-טים

קהל יעד: קרנות הון סיכון מובילות (a16z crypto, Paradigm, Sequoia), גופי משמורת מוסדיים וחברות ביקורת מובילות (OtterSec, Neodyme, Kudelski Security)
גרסת פרוטוקול: HAICHAIN Kernel v1.1 / CapLeaf v1 (סכמת Wire של 223 בייטים)
תקנים: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. תקציר מנהלים ופרדיגמת אבטחה

סוכני בינה מלאכותית אוטונומיים המבצעים מיקרו-תשלומים פיננסיים מציגים משטחי תקיפה שונים מהותית מ-DeFi המופעל על ידי בני אדם: 1. **אפס השהיית מעורבות אנושית:** סוכן AI המבצע קריאות כלים עלול להיחטף באמצעות הזרקת פרומפט עקיפה (Indirect Prompt Injection) ולהנפיק אלפי שוברי תשלום בלתי מורשים בתוך שניות. 2. **פגיעות דליפת מפתחות פרטיים:** הפעלת מופעי סוכנים על גבי צמתים מבוזרים מגבירה את הסיכון לחשיפת מפתחות. 3. **התרבות סוחרים זדוניים (Sybil):** ברשת M2M פתוחה, תוקפים יכולים לרשום דומיינים חד-פעמיים כדי לעקוף מגבלות קצב.

כדי לפתור זאת ללא פגיעה במהירות תת-מילישנייה, **HAICHAIN מפרידה לחלוטין בין ביצוע תשלומים למשמורת הון**: - **סמכות ריבונית עליונה:** מפתח חומרה ביומטרי WebAuthn FIDO2 Passkey (P-256) שומר על 100% בעלות ריבונית מוחלטת על הקופה. - **בידוד הרשאות תת-סוכנים:** מפתחות Ed25519 זמניים מבודדים בארגז חול בתוך מנוע המדיניות (Policy Engine) ללא גישה למילות השחזור של הארנק. - **עוגן מרקל על הבלוקצ'יין:** סכמת עלה של 223 בייטים אוכפת 9 אינווריאנטים מתמטיים (I_1 ... I_9).

2. מודל איומים פורמלי ותקרת הפסד (T_4)

בתרחיש הקיצון שבו מפתח ה-Ed25519 של הסוכן נחשף במלואו וקיים שיתוף פעולה עם סוחר מאומת בעץ המרקל, סך הגניבה המרבי $E_{theft}(\tau)$ מוגבל באופן מתמטי קשיח:

$$E_{theft}(\tau) \leq \min(B, \quad K, \quad W_p \cdot n(\tau, \omega_p), \quad \sum_{i:\, m_i \in <i>Ai>} E_i(\tau))$$

מסקנה מעשית: עבור קופה מוסדית עם יתרה של 10,000 USDT, תקרת עלה של 50 USDT ומגבלת קצב של 10 USDT / שעה, תוקף **לא יוכל לגנוב יותר מ-** 10 USDT לפני כניסת ההקפאה לתוקף, מה שמבטיח הגנה על 9,990 **USDT (99.9%)** מהקרן.

3. מטריצת הקשחה ו-9 אינווריאנטים

1. **מניעת תביעה כפולה באסקרו:** פדיון חד-כיווני בלתי הפיך ($P_i \leq \min(C_i, R_i)$.
2. **הגנת חשבון ATA קנוני:** מניעת ניתוב כספים לחשבונות זרים.
3. **בידוד הקפאת פאניקה (I_6):** ביטול מיידי של כל השוברים בתפוצה.
4. **השבת דמי שכירות (Lamports):** החזרה מלאה לקופה המקורית.

5. **בלימת מתקפות Sybil:** צריכה קשיחה של תקרת תקציב האב.

כל ההוראות ב- `programs/haichain-core/src/lib.rs` מצייתות ל-9 אינווריאנטים מתמטיים (I_1 ... I_9).

---

4. דוח ביקורת 9 אינווריאנטים מתמטיים (I_1 ... I_9)

כל ההוראות ב- `programs/haichain-core/src/lib.rs` שומרות על 9 אינווריאנטי המצב ללא יוצא מן הכלל:

1. I_1 (שימור הון מוחלט):

$$\text{סך הפקדות נטו} = \text{Refunds} + \sum \text{Paid}_j + \sum_{\text{channels}} \text{Escrow}_j + \text{Vault}_{\text{ATA}}$$

מאומת רשמית על ידי `test_invariant_i1_conservation` במערך הבדיקות.

2. I_2 (בטיחות מוטב קנוני):

$$\texttt{payee_ata} \equiv \texttt{get_associated_token_address}(\text{merchant}, \text{mint})$$

נאכף בשרשרת דרך אילוץ Anchor; מונע ניתוב מחדש של חשבונות טוקן.

3. I_3 (תקרת תקציב בלתי ניתנת לפריצה):

$$\texttt{budget_used} \le \texttt{budget_total} \quad \wedge \quad \text{consumed} \le \texttt{max_spend}$$

נבדק לפני כל ביצוע הקצאה או סילוקין בשרשרת.

4. I_4 (מגביל מהירות זרימה אוטונומי):

$$\forall\, t \in [T_0,\, T_0 + \omega] \qquad \texttt{window_used} \le \texttt{window_cap}$$

מונע ריקון הון מהיר ואוטומטי.

5. I_5 (הצרת הרשאות מונוטונית של PDA):

$$\text{Channel PDA} \subseteq \text{Grant PDA} \subseteq \text{Pot PDA}$$

מופעי צאצא אינם יכולים להרחיב הרשאות שניתנו על ידי ההורה.

6. I_6 (בידוד תקופת פאניקה והקפאה מיידית):

$$\texttt{pot.panic_epoch} == \texttt{channel.created_at_epoch} \quad \wedge \quad \neg\, \texttt{pot.frozen}$$

הקפאת חירום מבטלת באופן מיידי את כל השוברים שטרם סולקו.

7. I_7 (פקיעת תוקף ססגן):

$$\texttt{current_time} \le \texttt{valid_until}$$

ססגנים שפג תוקפם אינם יכולים לבצע הקצאות חדשות של הון.

8. I_8 (סילוקין מונוטוני וחד-פעמי):

$$\text{paid}_{\text{new}} \le \min(\texttt{cumulative_amount}, \texttt{reserved_amount}) \quad \wedge \quad \text{paid}_{\text{new}} \ge \text{paid}_{\text{old}}$$

מבטיח אפס הוצאה כפולה בין שוברים ומונע מתקפות שידור חוזר.

9. I_9 (בידוד חשבונות נגד התקפת סיביל):

ייחודי $(\texttt{PDA}(\text{"chan"}, \text{grant}, \texttt{channel_id})$

עלה יכולת ממופה בדיוק לחשבון בשרשרת יחיד.
